

SentinelX: A Continuous External Attack Surface Intelligence Platform for Graph-Based Second-Order Exposure Detection

A Research Proposal and System Design

[Author Name(s) — Affiliation — Contact]

Abstract

External Attack Surface Management (EASM) platforms have matured commercially as discovery-and-inventory tools, yet none publish a reproducible risk-scoring methodology, and none model an organization's asset inventory as a relationship graph correlated against externally observed threat infrastructure. This paper identifies that gap through (i) a review of commercial EASM documentation showing a consistent absence of published risk models and graph-native correlation, (ii) a review of cyber threat intelligence (CTI) knowledge-graph literature showing that existing graph-based approaches target attacker infrastructure or internal security-operations correlation rather than defender-side external asset inventories, and (iii) analysis of four verified, independent cyber incidents (2023–2025) spanning distinct exposure classes that no single existing EASM category addresses. We propose SentinelX, a platform architecture built around a typed asset-relationship graph fused with CTI correlation, and a risk-scoring function that treats graph position — not only asset-intrinsic features — as a first-class input. We state explicitly which claims are validated, which are design assumptions pending calibration, and which require future work, and we propose (rather than report) an evaluation methodology, since no standardized EASM benchmark currently exists in the literature.

Keywords

External Attack Surface Management, Attack Surface Intelligence, Cyber Threat Intelligence, Graph Databases, Risk Scoring, Security Analytics, Continuous Exposure Management, OSINT

1. Introduction

Enterprise IT has decentralized faster than enterprise security visibility has kept pace with it. Cloud tenancy, SaaS adoption, third-party managed services, and internet-facing enterprise software have expanded what counts as an organization's perimeter well beyond what any static asset inventory captures. Four recent, independently documented incidents illustrate this gap concretely, and each corresponds to a structurally different category of external exposure.

1.1 Case 1 — Unpatched, Internet-Facing Software (MOVEit, 2023)

In May 2023, the CL0P ransomware group (tracked by Microsoft as Lace Tempest, associated with the actor cluster FIN11) exploited a previously unknown SQL injection vulnerability, CVE-2023-34362, in Progress Software's MOVEit Transfer managed file transfer application, deploying a web shell named LEMURLOOT that enabled attackers to execute commands and exfiltrate data from underlying databases [1]. Independent internet-wide scanning by Censys identified more than 3,000 MOVEit hosts exposed to the internet before the vulnerability was disclosed or patched [2]. Reported victim totals vary by source and reporting date: Progress released a patch on May 31, 2023; by October 2023 a running industry tally cited over 2,500 affected organizations, while later aggregated reporting placed the total at over 2,700 organizations and approximately 93.3 million affected individuals [3]. This is the canonical

unknown/unmonitored internet-facing-software exposure category — the vulnerability itself was zero-day, but exposure to it was a discoverable, pre-existing condition.

1.2 Case 2 — Identity and Configuration Exposure Without a Software Vulnerability (Snowflake, 2024)

In contrast to MOVEit, the Snowflake campaign involved no exploited software flaw. Mandiant's investigation concluded that Snowflake's own infrastructure was not compromised; instead, threat actors used credentials previously stolen by infostealer malware to log directly into customer tenants that had not enforced multi-factor authentication [4]. Compounding factors included credentials that had not been rotated for as long as four years and the absence of network allow-lists restricting access to trusted locations [5]. Approximately 165 customer organizations were affected, including AT&T (call/text metadata for roughly 110 million customers) and Ticketmaster (roughly 560 million records) [4],[6]. This exposure class involves no CVE and no patch — a configuration and identity-posture gap in third-party SaaS access that vulnerability-centric tooling does not register as an issue at all.

1.3 Case 3 — Known, Unpatched Exposure at Scale (Jaguar Land Rover, 2025)

Beginning around August 31, 2025, an intrusion later attributed by Microsoft and a New York Times investigation to a Russia-linked hacking group shut down production across Jaguar Land Rover's (JLR) factories for nearly six weeks, with the Cyber Monitoring Centre (CMC) independently assessing total UK economic loss at £1.9 billion — the most financially damaging cyberattack in UK history [7],[8]. Technical post-incident analysis indicates the attackers did not require a zero-day exploit: JLR's SAP systems had not applied patches for known SAP NetWeaver flaws that CISA had already warned were under active exploitation months earlier, with more than 1,100 SAP systems worldwide compromised via the same unpatched flaws [9]. This is a third, distinct exposure class: a known vulnerability, on internet-reachable enterprise software, that remained unremediated for months despite public advisories.

1.4 Case 4 — Third-Party Concentration Risk via a Legacy Remote-Access Portal (Change Healthcare, 2024)

On February 12, 2024, ALPHV/BlackCat affiliates used stolen employee credentials to access a Change Healthcare Citrix remote-access portal that did not have multi-factor authentication enabled — a portal acquired through a prior corporate acquisition and never fully integrated into UnitedHealth Group's security controls, per CEO Andrew Witty's congressional testimony [10]. Attackers moved laterally undetected for nine days before deploying ransomware on February 21, 2024, exfiltrating approximately 4 TB of data [11]. Because Change Healthcare processes a large share of U.S. medical claims and prescription transactions, the outage cascaded nationally; UnitedHealth reported over \$2.8 billion in direct breach-related costs for 2024 alongside a \$22 million ransom payment, with affected-individual estimates rising to approximately 190 million as forensic analysis continued [11],[12]. This case demonstrates concentration risk: the assets that matter to an organization's risk posture are not necessarily its own assets, but those of a critical vendor it structurally depends on.

Taken together, these four incidents span a taxonomy that no single existing EASM category fully addresses: unknown exposure of internet-facing software prior to disclosure, identity/configuration exposure with no associated CVE, known-but-unremediated exposure that persisted despite public advisories, and third-party concentration risk. This motivates a platform architecture built around continuous, relationship-aware exposure modeling rather than point-in-time, per-asset scanning.

2. Motivation

The motivation for SentinelX is not that organizations need better vulnerability scanning — the four cases above show that vulnerability scanning, even where it exists, is not the limiting factor. In MOVEit, the flaw was unknown; no scanner could have flagged it before disclosure. In Snowflake, there was no vulnerability to scan for. In JLR, the vulnerability was known and publicly advised on months before exploitation, yet remained unpatched at internet-facing scale. In Change Healthcare, the exposure belonged to a vendor, not the affected downstream organizations. Across all four, the actual bottleneck is exposure awareness and verification continuity — not vulnerability discovery: organizations did not reliably know which internet-facing assets they had, which third-party or SaaS-adjacent identity surfaces extended their effective perimeter, whether a known remediation had actually propagated to every exposed instance, or how exposed their critical vendors were.

This is precisely the class of problem EASM platforms claim to solve, and precisely where this work's proposed novelty differs from existing commercial approaches. MOVEit and JLR both involve shared, widely deployed third-party software — the relevant risk signal is not "we have an asset" but "we run software that is part of a class of internet-exposed instances currently under active exploitation elsewhere," which is fundamentally a graph/correlation problem rather than a lookup problem. Snowflake demonstrates that attack surface must extend to third-party SaaS identity configuration, which most EASM tools — built around IP, domain, and certificate discovery — do not model. Change Healthcare demonstrates that attack surface must, in principle, extend to critical vendor dependencies, which no EASM tool currently models at all.

3. Problem Statement

Organizations lack a continuously updated, relationship-aware model of their external exposure that unifies (i) authorized internet-facing asset discovery, (ii) third-party and SaaS-adjacent identity/configuration exposure, and (iii) real-time correlation against known-exploited infrastructure and vulnerability classes — and that expresses risk as a function of an asset's position within this relationship structure rather than as an isolated, per-asset score. Existing EASM platforms address asset discovery and per-asset risk scoring; none publish a reproducible, graph-derived model of exposure risk, and none extend discovery to the identity/configuration or vendor-dependency exposure classes demonstrated above.

Formally, given an organization's set of authorized assets A , we require a function:

$$R : A \times G \rightarrow [0, 1]$$

that computes exposure risk for each asset $a \in A$ as a function not only of a 's intrinsic properties (software version, open ports, TLS configuration) but of a 's position in a graph G that includes shared-infrastructure relationships (shared certificates, shared hosting ASN, shared software fingerprints) and edges to externally observed threat infrastructure (CTI feeds, known-exploited-CVE-associated hosts). No published EASM methodology defines R over G in this form; existing tools compute R over A alone.

4. Research Gap

We identify four specific gaps, deliberately scoped to avoid the diluted-contribution problem common in systems papers that claim many things shallowly rather than one thing rigorously. RG1 is the flagship

contribution; RG2 is a directly supporting contribution; RG3 and RG4 are evidence-driven scope extensions with explicitly weaker observability guarantees than RG1–RG2.

RG1 (Flagship) — Attack Surface as Graph, Not Inventory

Existing EASM platforms model attack surface as an inventory — a list of assets, each independently scored. None model the attack surface as a graph capturing shared-infrastructure relationships between an organization's own assets and externally observed threat infrastructure. This matters directly because of Cases 1 and 3: an organization running a widely deployed MFT or ERP component is not adequately served by "we found this asset and it has no currently known CVE" — it needs "this asset belongs to a software class currently under active mass-exploitation elsewhere," which requires correlating the organization's own graph node against external CTI graph structure. This correlation, at the graph level, is not published as an academic contribution targeting defender-side asset inventories, and is not exposed as a first-class feature in commercial EASM documentation reviewed in Section 6.

RG2 (Supporting) — Graph-Derived, Reproducible Risk Scoring

No EASM literature defines a risk-scoring function that takes graph-derived features (node centrality, shared-infrastructure proximity to known-malicious or known-exploited nodes, blast-radius if a shared component is compromised) as first-class inputs, as distinct from asset-intrinsic features. Case 3 (JLR) is illustrative: a graph-aware model could, in principle, weight "internet-facing SAP NetWeaver instance, publicly advised five months prior, part of a widely deployed vulnerable-instance cluster" far higher than an isolated CVSS score would, because the risk signal is amplified by cluster membership — a property invisible to per-asset scoring.

RG3 (Scope Extension) — SaaS Identity/Configuration as an Asset Class

Case 2 (Snowflake) demonstrates that "external attack surface," as currently defined by commercial EASM (IP/domain/certificate/port-centric), excludes an entire exposure class: third-party SaaS identity and access configuration (MFA enforcement status, credential rotation age, allow-list presence). This is treated as a scoped graph extension rather than an independent flagship claim. Caveat: SaaS identity posture is not always externally discoverable without API-level access grants, unlike DNS/certificate/port data, which is genuinely OSINT-observable — this observability gap is weaker than RG1's and must be stated as such.

RG4 (Scope Extension) — Vendor/Third-Party Dependency Modeling

Case 4 (Change Healthcare) shows that external attack surface, properly conceived, includes the exposure posture of critical third parties an organization structurally depends on. This is a graph-native problem by construction and is folded into RG1's schema as a typed dependency edge rather than treated as an independent fifth flagship claim. Caveat: an organization typically cannot directly observe another company's MFA configuration or credential hygiene, so RG4's graph edge must be populated from indirect signals — public breach disclosures, CTI vendor-risk feeds, regulatory filings, or shared-infrastructure fingerprinting of the vendor's own internet-facing assets — giving it a meaningfully weaker observability guarantee than RG1.

What these gaps do not claim, stated explicitly: SentinelX is not claimed to have prevented any of the four incidents above. MOVEit was a zero-day — no exposure model detects an unknown vulnerability before disclosure; the plausible contribution there is faster post-disclosure triage, not prevention. For JLR, the plausible contribution is elevating the priority of a known-but-unpatched internet-facing instance above

where a flat CVSS-only view would rank it — a prioritization claim, not a prevention guarantee. For Snowflake and Change Healthcare, any contribution is contingent on RG3/RG4's scope extensions being implemented and depends on external data actually being observable, which is not guaranteed.

5. Literature Review

Search strategy: targeted queries against IEEE Xplore-indexed and arXiv-hosted sources, restricted to results with a resolvable DOI or arXiv identifier, across three clusters — (a) EASM as a named research field, (b) vulnerability and exposure risk scoring, and (c) CTI knowledge graphs and graph-based security correlation.

5.1 EASM Has No Peer-Reviewed Research Base

Direct searches for "external attack surface management" academic literature returned almost exclusively vendor content and a single USPTO patent filing for an attack-surface-management platform architecture — not IEEE, ACM, or arXiv papers. This absence is itself a citable finding: EASM is a mature product category without a corresponding peer-reviewed literature, which motivates the evaluation-methodology gap (RG-E) discussed further in Section 12.

5.2 Vulnerability and Exposure Risk Scoring

The Exploit Prediction Scoring System (EPSS), maintained by FIRST.org, is the closest existing peer-reviewed analogue to the risk-scoring contribution proposed here: a data-driven machine-learning model estimating the probability that a published CVE will be exploited in the wild within 30 days, using empirical exploitation signals rather than subjective severity judgments alone [13]. FIRST does not disclose EPSS's underlying training data or source code, though the general methodology has been published academically [14]. Independent empirical evaluation of EPSS against the CISA Known Exploited Vulnerabilities (KEV) catalog exists in the literature [15], as does broader comparative work on vulnerability scoring systems [16] and integrated vulnerability-prioritization frameworks [17]. Critically, EPSS operates entirely at the level of an individual CVE and does not incorporate any notion of an asset's position within a shared-infrastructure graph — reinforcing that graph-derived risk features, as proposed in RG2, are a genuine extension rather than a re-derivation of EPSS-style scoring.

5.3 CTI Knowledge Graphs

This cluster is the most directly relevant prior work for RG1 and requires the most careful positioning. Verified contributions include: Open-CyKG, an open CTI knowledge-graph extraction framework [18]; HinCTI, a threat-intelligence modeling and identification system based on heterogeneous information networks [19]; AttackKG/AttacKG, linking CTI to MITRE ATT&CK tactics and constructing technique knowledge graphs from CTI reports [20],[21]; attack-hypothesis generation based on a threat-intelligence knowledge graph [22]; combined LLM-and-knowledge-graph approaches for actionable CTI extraction [23]; a survey of knowledge-graph application scenarios in cybersecurity [24]; graph-based cyber situational awareness [25]; a Neo4j-based OSINT threat-hunting and vulnerability-analysis system [26]; a graph-based correlation approach for multi-step cyberattack detection [27]; an industrial billion-scale security-incident correlation system [28]; and a systematic review of security event correlation methods [29].

Every one of these graph-based approaches models either (a) attacker infrastructure or technique relationships (CTI-side) or (b) internal alert and incident correlation (SOC-side). None found in this review model a defender's own external asset graph fused with CTI infrastructure data to detect second-order exposure — i.e., that an organization's own asset shares infrastructure fingerprints with something CTI has already flagged. Reference [26], a Neo4j-based OSINT threat-hunting prototype, is the closest existing academic work to the SentinelX graph layer and requires a full comparative read before finalizing any novelty claim in a submitted version of this work, as it is the most likely candidate for a reviewer to cite as prior art.

Positioning: the literature review does not claim SentinelX invents graph-based cybersecurity analytics generally. The accurate, narrower claim is that applying an entity-relationship graph specifically to the defender-side external-asset-inventory problem, fused with CTI correlation for second-order exposure detection, and paired with a graph-feature-driven risk function, is not represented in either the EASM product literature (which has none) or the CTI-graph academic literature (which targets attacker infrastructure or SOC alerts, not defender asset inventories).

6. Existing Solutions and Comparative Analysis

Methodological caveat: several sources consulted for this comparison are competitor-authored marketing content (particularly IONIX-published comparison pages), and their characterizations of rival products' limitations should be treated as claims requiring independent corroboration from each vendor's own documentation before being relied upon in a submitted version of this work. Table 1 uses only claims that are either self-reported by the vendor or corroborated across multiple independent sources; single-source competitor claims are marked as unverified.

Dimension	Cortex Xpanse	MS Defender EASM	CyCognito	Censys	Tenable One	SentinelX (proposed)
Discovery method	Internet-wide port scanning (500B ports/day claimed)	Seed-based enumeration	Seedless, algorithmic attribution	Passive internet-wide scanning; explicitly a data layer, not an operational platform	Internal-first (Nessus heritage) + external module	Hybrid OSINT + CTI-correlated discovery
Entity/subsidiary modeling	Not a primary capability per published docs	Not built before discovery per published docs	Algorithmic (single-source claim, unverified)	N/A	Not a core design point	Explicit typed-graph entity model (RG1)
Risk scoring transparency	Proprietary, undisclosed	Proprietary, undisclosed	Proprietary, undisclosed	N/A	Proprietary, undisclosed	Published, reproducible formula (RG2)
Graph-native CTI correlation	XDR telemetry correlation (internal, not CTI-infra)	Not documented	Not documented	Data layer only	Not documented	Core mechanism (RG1)

Dimension	Cortex Xpanse	MS Defender EASM	CyCognito	Censys	Tenable One	SentinelX (proposed)
SaaS identity/config posture	Not documented as core scope	Not documented as core scope	Not documented as core scope	Out of scope by design	Not documented as core scope	Proposed extension, weak observability (RG3)
Vendor dependency modeling	Not a primary capability	Not documented	Unverified single-source claim	Out of scope	Not documented	Proposed extension, weak observability (RG4)
Peer-reviewed basis	None found	None found	None found	Used as data source by researchers; platform itself not peer-reviewed	None found	This work

Table 1. Documented capabilities of major commercial EASM platforms vs. SentinelX's proposed scope. Absence of a documented claim is not proof of absence of the capability.

Reading this table critically: the "SentinelX" column is aspirational — it describes what is proposed to be built and evaluated, not a completed and validated system, and must never be presented as reporting completed results. What the table does support is that no commercial row publishes a risk-scoring formula, and none document graph-native correlation between an organization's own assets and external CTI infrastructure — a consistency across independently operated products that, even accounting for source bias in some entries, is reasonably strong evidence for RG1 and RG2. RG3 and RG4 are less directly evidenced by this table, since absence of a public claim is not confirmed absence of the underlying capability; Section 11 states this limitation explicitly.

7. Proposed Methodology

SentinelX is developed as a four-stage pipeline:

- **Discovery** — hybrid passive (certificate transparency, passive DNS, WHOIS/ASN expansion) and active (banner grabbing, TLS fingerprinting) reconnaissance, seeded from organization-provided, authorized root assets.
- **Graph Construction** — every discovered asset becomes a typed node; relationships (shared certificate, shared ASN, shared software fingerprint, vendor/dependency links) become typed edges; externally observed CTI indicators are ingested as a second node class connected to organizational nodes wherever a shared-attribute edge exists.
- **Risk Scoring** — every asset node receives a score from the composite function defined in Section 9, combining intrinsic exposure features with graph-position features.
- **Continuous Monitoring** — scheduled re-discovery on a configurable interval, with change alerts weighted by risk-significance (Section 8) rather than raw syntactic difference.

This section describes proposed methodology; Sections 13–15 define how each stage would actually be tested, and no results are claimed here.

8. System Architecture and Continuous Monitoring Algorithm

8.1 Layered Architecture

- Ingestion Layer — connectors to passive DNS, certificate transparency (crt.sh), WHOIS/RDAP, ASN/BGP data, and CTI feeds (CISA KEV, AlienVault OTX).
- Fingerprinting Layer — active probing, rate-limited and scope-restricted to authorized root-asset ranges, for open ports, TLS certificates, and HTTP/technology fingerprinting.
- Graph Store — a property graph database (e.g., Neo4j) holding the node/edge schema defined in Section 10.
- Relational/Time-Series Store — PostgreSQL for asset metadata and audit trail; a time-series extension for historical snapshots feeding change detection.
- Risk Engine — computes the composite score $R(a)$ on each discovery cycle and recomputes graph-position features whenever graph topology changes.
- Presentation Layer — executive dashboard (aggregate exposure trend) and technical dashboard (graph explorer, per-asset drill-down).

Only the Risk Engine and its dependence on graph topology constitute the architecturally novel component; the remaining layers follow standard EASM engineering practice documented across the vendor sources reviewed in Section 6 and should not be presented as novel contributions in their own right.

8.2 Continuous Monitoring Algorithm

A naive change-detection approach alerts whenever a snapshot differs from the prior cycle, which produces alert fatigue because a cosmetic certificate renewal and a newly opened administrative port receive equal weight. We instead define a significance-weighted change score:

$$\Delta t(a) = |R_t(a) - R_{t-1}(a)| \times C(a)$$

where $R_t(a)$ is the composite risk score (Section 9) at monitoring cycle t and $C(a) \in [0,1]$ is an organization-supplied business-criticality weight — an explicit input, not an inferred one. An alert fires when $\Delta t(a)$ exceeds a configurable threshold τ . This directly operationalizes the change-significance gap identified in prior EASM tooling as a derivative of the risk function itself, rather than as an independent algorithmic contribution; it should not be presented as a fourth flagship contribution.

Algorithm 1: Continuous Monitoring Cycle

for each asset a in inventory: $S_t(a) \leftarrow \text{discover_and_fingerprint}(a)$; $\text{update_graph_edges}(a, S_t(a))$; $R_t(a) \leftarrow \text{compute_risk}(a, \text{Graph}_t)$; $\Delta_t(a) \leftarrow |R_t(a) - R_{t-1}(a)| \times C(a)$; if $\Delta_t(a) > \tau$ then $\text{emit_alert}(a, \Delta_t(a), \text{diff}(S_t(a), S_{t-1}(a)))$; $\text{persist}(S_t(a), R_t(a))$.

9. Mathematical Risk Scoring Model

This section states every assumption explicitly rather than embedding it inside an unexplained coefficient, since this model is the load-bearing contribution (RG2).

9.1 Intrinsic Risk Component

$$I(a) = w1 \cdot \text{EPSS}(a) + w2 \cdot \text{ExposureSeverity}(a) + w3 \cdot \text{PatchLatency}(a)$$

- $\text{EPSS}(a)$: if asset a has an associated CVE, use FIRST's published EPSS probability directly [13] — building on an existing, validated external model rather than re-deriving exploit-likelihood estimation.

- ExposureSeverity(a): a normalized score from exposed-service characteristics (unauthenticated admin panel > authenticated service > standard HTTPS service). This taxonomy and its numeric weights are an assumption requiring expert-panel calibration (Section 14), not a validated psychometric scale.
- PatchLatency(a): normalized time since a public advisory (e.g., CISA KEV addition date) without confirmed remediation — directly motivated by Case 3, where exposure duration itself was the dominant risk driver, independent of exploit probability.
- w1, w2, w3: weights summing to 1, initialized via practitioner elicitation and refined via the evaluation described in Section 14; no claim of an optimal or learned value is made at this stage.

9.2 Graph-Position Risk Component

$$P(a) = 1 - \prod_{v \in F} (1 - w(a,v) \cdot e^{(-\lambda \cdot d(a,v))})$$

where F is the set of CTI-flagged nodes in the graph, $d(a,v)$ is shortest-path distance from asset a to flagged node v , $w(a,v) \in [0,1]$ is the edge-type relationship strength along that path (e.g., shared TLS certificate weighted higher than shared hosting ASN, since certificate reuse is a stronger operational-relationship signal than mere co-location), and $\lambda > 0$ is a decay constant. The noisy-OR product form reflects that risk from multiple independent flagged-node proximities should compound rather than simply sum past 1. The specific $w(a,v)$ values and λ are design parameters to be calibrated empirically against the case-study replay in Section 15, not values derived from data in this proposal.

9.3 Composite Risk Score

$$R(a) = \alpha \cdot I(a) + \beta \cdot C(a) \cdot P(a), \quad \alpha + \beta = 1$$

Multiplying $P(a)$ by organizational criticality $C(a)$, rather than treating $P(a)$ as a flat additive term, encodes the design intuition from Case 3: a low-criticality asset's second-order proximity to threat infrastructure should not dominate the score the way a high-criticality asset's proximity should. This is a defensible modeling choice, not an empirically validated one; an ablation comparing $R(a)$ with and without this multiplicative interaction against labeled incident data is identified as required future evaluation in Section 14, not claimed as already performed.

10. Threat Intelligence Model, Discovery Workflow, and Graph Database Design

10.1 Threat Intelligence Model

CTI ingestion populates the flagged-node set F used in $P(a)$. Sources are scoped to what is genuinely accessible without commercial contracts: the CISA Known Exploited Vulnerabilities catalog (structured, free, authoritative), AlienVault OTX pulses (community-sourced, free API), and certificate-transparency-derived infrastructure clustering (crt.sh, free). Each source maps to a specific node/edge type: a KEV entry becomes a `VulnerableSoftwareClass` node linked to any organizational asset whose fingerprint matches the affected software/version range; an OTX indicator becomes a `ThreatInfrastructure` node linked via shared-IP or shared-certificate edges where they exist.

Honest limitation: commercial CTI feeds (e.g., paid Shodan/Censys tiers, JARM/JA3 fingerprinting at scale) provide materially richer infrastructure-clustering signal than the free sources above. Any evaluation of second-order detection capability must be scoped to what free-tier CTI can actually surface; claiming production-grade coverage without that access would be an unjustified claim.

10.2 Attack Surface Discovery Workflow

- Seed input: organization-provided, authorized root domains/IP ranges.
- Passive expansion: certificate-transparency subdomain enumeration; passive DNS historical association; WHOIS/RDAP and ASN lookup for IP-range ownership expansion.
- Active fingerprinting: rate-limited, scope-restricted TCP/TLS probing — banner grab, certificate extraction, HTTP header/technology detection.
- Attribution confidence scoring: each asset receives a confidence score reflecting certainty of organizational ownership (direct WHOIS match = high; shared-hosting-provider inference = low) — this carries attribution uncertainty as a node attribute rather than a binary include/exclude decision, which is noted here as a design accommodation for future probabilistic modeling (Section 16), not implemented as a full Bayesian model in this proposal's scope.
- Graph ingestion: asset becomes a node; discovered relationships become typed edges.
- CTI correlation: graph queried for shortest paths to any flagged CTI node (Section 10.1).
- Risk scoring and alerting: Sections 8.2 and 9.

10.3 Database Design

Polyglot persistence, with each engine used for what it is suited to: PostgreSQL (relational) stores organization metadata, access control, audit logs, and raw discovery records — the system of record for compliance, which a graph database is not well suited for. A time-series extension (e.g., TimescaleDB) stores historical risk-score and snapshot data feeding change detection. Neo4j (graph) stores the asset/relationship/CTI graph itself.

10.4 Graph Database Model

Node types: Organization, Asset (subtyped Domain, IPAddress, Certificate, CloudResource), SoftwareFingerprint, ThreatInfrastructure, VulnerableSoftwareClass, Vendor (for RG4).

Edge types: OWNS (Organization→Asset, weighted by attribution confidence), SHARES_CERTIFICATE_WITH, SHARES_ASN_WITH, RUNS_SOFTWARE, MATCHES_VULNERABLE_CLASS, FLAGGED_BY_CTI, DEPENDS_ON_VENDOR.

Representative query for second-order exposure detection — the literal operationalization of RG1's core claim:

```
MATCH (o:Organization {name:$org})-[:OWNS]->(a:Asset) MATCH (a)-[:SHARES_CERTIFICATE_WITH|SHARES_ASN_WITH*1..3]-(x:Asset)-[:FLAGGED_BY_CTI]->(t:ThreatInfrastructure) RETURN a, x, t, length((a)-[*1..3]-(t)) AS distance ORDER BY distance ASC
```

This is the one query a flat-inventory competitor architecture cannot run, since it requires graph-native shortest-path traversal across both organizational and CTI node types — making it the most important capability to validate correctly for both the research contribution and any subsequent prototype.

11. Evaluation Methodology, Performance Metrics, and Experimental Design

No standardized EASM benchmark currently exists in the literature (Section 5.1). We therefore propose an evaluation protocol rather than assume one, and report no results here, since none have been collected.

11.1 Evaluation Methodology

- Discovery completeness: a small curated ground-truth asset inventory (volunteer organizations or a deliberately constructed lab environment) to measure discovery-stage recall. Disclosed as small-scale and non-representative of enterprise complexity.
- Attribution precision: manual analyst review of a sample of attribution-confidence labels, reported as precision/recall rather than a single obscuring accuracy figure.
- Second-order exposure utility (the flagship claim's actual test): a counterfactual case-study replay — reconstructing, from public CTI timelines, the shared-infrastructure signals retrospectively available around the MOVEit and JLR incidents, injecting a synthetic organizational asset graph containing analogous exposed instances, and measuring whether the graph-correlation query in Section 10.4 would have surfaced the exposure earlier than a flat CVE-lookup baseline. This is a counterfactual replay against historical public data, not a live prediction, and must be presented as such.
- Risk-ranking quality: Kendall's τ rank correlation between R(a) output and independent analyst-assigned severity rankings on a shared sample set — validating ranking usefulness without fabricating an accuracy percentage that risk scores do not actually have ground truth for.

11.2 Performance Metrics

- Discovery recall/precision (Section 11.1).
- Mean time-to-flag: interval between a CVE's addition to CISA KEV and SentinelX flagging any matching organizational asset.
- Second-order alert precision/recall against analyst-labeled ground truth.
- Kendall's τ for risk-ranking agreement.
- System throughput (assets fingerprinted per hour at a given rate-limit configuration) and graph-query latency (p50/p95) for the second-order correlation query at realistic asset-graph sizes.

No numeric values are asserted for any metric in this document — they describe what the proposed experimental design would produce, not results already obtained.

11.3 Experimental Design

Phase 1 (lab validation): deploy against a small set of intentionally instrumented assets with known ground truth to validate discovery/attribution pipelines. Phase 2 (volunteer pilot): a time-boxed (4–8 week) continuous-monitoring pilot with a small number of consenting organizations or lab domains, comparing graph-correlation alerts against a flat-inventory baseline using the same underlying discovery data as a control condition. Phase 3 (historical replay): the counterfactual case-study replay described in Section 11.1. Explicitly out of scope: enterprise-scale deployment, commercial CTI feed access, and any claim of production-representative results — named as future work (Section 15), not implied as already achieved.

12. Security Considerations

SentinelX itself becomes a high-value target the moment it exists: a working copy of an organization's complete external exposure graph, including second-order weaknesses, is precisely what an attacker would want. Required controls include encryption at rest and in transit for the graph and relational stores; strict least-privilege scoping of active-probing credentials, such that the platform never holds more access than the specific authorized scan targets require; rate-limiting on active fingerprinting to avoid inadvertent denial-of-service against target infrastructure, both an ethical and, in most jurisdictions, a legal requirement; and integrity controls on CTI feed ingestion, since a poisoned or manipulated feed could cause the risk engine to systematically under- or over-score specific assets. An adversary who understood the scoring

function could attempt to manufacture benign-looking shared-infrastructure signals to game P(a) — a novel attack surface on the research contribution itself, worth naming explicitly rather than omitting.

13. Ethical Considerations

All active discovery must be scoped to explicitly authorized asset ranges as a hard architectural constraint — an enforced allow-list at the fingerprinting layer, not merely a policy. For RG4 (vendor/third-party dependency modeling), active probing of a vendor's infrastructure without the vendor's authorization is both an ethical and likely legal problem; RG4 must therefore be restricted to passive, publicly disclosed signals only (breach disclosures, public CTI, regulatory filings, the vendor's own public-facing asset fingerprints observable the same way any public entity's assets are), never active scanning of a third party the subscribing organization does not own. Any incidentally discovered personally identifiable information (e.g., within an exposed misconfigured storage bucket) requires data-minimization handling and, where applicable, responsible-disclosure procedures rather than retention for platform purposes. Given the platform's dual-use potential — the same discovery and correlation capability that helps a defender find their own exposure could help an attacker map a target — any publication or release should include a clear statement of intended use and access controls, consistent with responsible-disclosure norms in security research.

14. Limitations

- Evaluation (Section 11) is necessarily small-scale, using free-tier CTI and OSINT sources; results would not be representative of enterprise-scale or commercial-CTI-augmented deployments.
- The risk-model weights in Section 9 are design assumptions pending empirical calibration; no claim of optimality is made.
- RG3 and RG4 depend on external observability that is, in many cases, not actually available without API-level access grants from the SaaS provider or vendor; both are scoped as partial, evidence-limited extensions, not fully realized capabilities.
- Graph-based shared-infrastructure correlation is inherently prone to false positives from coincidental co-location (e.g., two unrelated organizations sharing a large cloud provider's IP range does not imply meaningful risk correlation); the edge-weighting scheme in Section 9.2 attempts to mitigate this but has not been validated against adversarial or noisy real-world data at scale.
- Attribution confidence (Section 10.2) is represented as a node attribute in the schema but not implemented as a full probabilistic model in this proposal's scope; this remains future work.
- The counterfactual replay methodology (Section 11.1) demonstrates plausibility, not causally validated prevention. This work does not claim SentinelX would have prevented any of the four incidents analyzed in Section 1 — only that it could plausibly surface relevant signal earlier or with higher priority than a flat-inventory baseline, and even that claim is bounded by the replay's synthetic construction.
- The closest related academic work identified in Section 5.3 — a Neo4j-based OSINT threat-hunting prototype [26] — requires a full comparative read before any final novelty claim can be considered settled; this proposal's RG1 claim should be treated as provisional pending that review.

15. Future Enhancements

- Production-scale evaluation with commercial CTI partnerships (JARM/JA3 fingerprint corpora, paid Censys/Shodan tiers).
- A Bayesian attribution-confidence model fully integrating attribution uncertainty rather than treating it as a static node attribute.
- Automated remediation-orchestration integration (ticketing/SOAR systems).
- Public release of the counterfactual replay dataset and methodology as an open benchmark, directly addressing the field-wide evaluation-methodology gap identified in Section 5.1, not only this platform's own evaluation.
- Longitudinal validation against a larger set of real, post-hoc incident timelines beyond the four analyzed in this work.
- Extension of the graph schema to represent OT/ICS-adjacent internet-facing assets, an increasingly relevant exposure class per recent industrial-sector CTI reporting.

16. Conclusion

Existing EASM platforms have matured as discovery-and-inventory products but have not published a reproducible risk-scoring methodology or a graph-native model connecting an organization's own assets to externally observed threat infrastructure — a gap evidenced both by the absence of peer-reviewed EASM literature (Section 5.1) and by the consistent absence of these specific capabilities across major commercial products' public documentation (Section 6). Four recent, independently verified incidents — MOVEit, Snowflake, Jaguar Land Rover, and Change Healthcare — collectively span an exposure taxonomy that no single existing exposure category adequately covers, motivating the graph-based model proposed here. The contribution proposed in this work — a typed asset-relationship graph fused with CTI correlation, and a risk-scoring function that takes graph position as a first-class input — is scoped narrowly and evaluated honestly: as a plausibility-demonstrating prototype validated through small-scale pilots and historical counterfactual replay, not as a production-validated system. That scoping is deliberate; claiming less while proving it rigorously is expected to withstand peer review better than a broader claim that cannot be substantiated with available data.

References

- [1] CISA, "#StopRansomware: CL0P Ransomware Gang Exploits CVE-2023-34362 MOVEit Vulnerability," Cybersecurity Advisory AA23-158A, Jun. 2023. [Online]. Available: <https://www.cisa.gov/news-events/cybersecurity-advisories/aa23-158a>
- [2] Cybersecurity Dive, "MOVEit mass exploit timeline: How the file-transfer service attacks entangled victims," 2023. [Online]. Available: <https://www.cybersecuritydive.com/news/moveit-breach-timeline/687417/>
- [3] Wikipedia, "2023 MOVEit data breach." [Online]. Available: https://en.wikipedia.org/wiki/2023_MOVEit_data_breach
- [4] Google Cloud / Mandiant, "UNC5537 Targets Snowflake Customer Instances for Data Theft and Extortion," Jun. 2024. [Online]. Available: <https://cloud.google.com/blog/topics/threat-intelligence/unc5537-snowflake-data-theft-extortion>
- [5] DarkReading, "Snowflake Cloud Accounts Felled by Rampant Credential Issues," Jun. 2024. [Online]. Available: <https://www.darkreading.com/cloud-security/snowflake-cloud-accounts-rampant-credential-issues>
- [6] Wikipedia, "Snowflake data breach." [Online]. Available: https://en.wikipedia.org/wiki/Snowflake_data_breach
- [7] Cyber Monitoring Centre, "Statement on the Jaguar Land Rover Cyber Incident," Oct. 2025. [Online]. Available: <https://cybermonitoringcentre.com/2025/10/22/cyber-monitoring-centre-statement-on-the-jaguar-land-rovercyber-incident-october-2025/>
- [8] The Next Web, "Russian hackers were behind the Jaguar Land Rover attack that cost the British economy two and a half billion dollars," 2026. [Online]. Available: <https://thenextweb.com/news/jaguar-land-rover-hack-russian-hackers-nyt-investigation>
- [9] Kegate, "Jaguar Land Rover JLR 2025 Cyberattack — Technical Analysis," Nov. 2025. [Online]. Available: <https://kegate.com/jaguar-land-rover-jlr-2025-cyberattack-technical-analysis/>
- [10] TechTarget, "Change Healthcare breached via Citrix portal with no MFA," Apr. 2024. [Online]. Available: <https://www.techtarget.com/searchsecurity/news/366582824/Change-Healthcare-breached-via-Citrix-portal-with-no-MFA>
- [11] Cloudskope, "Change Healthcare Breach 2024: \$872M Attack." [Online]. Available: <https://www.cloudskope.com/breaches/change-healthcare-breach-2024>
- [12] Censinet, "Lessons from Change Healthcare Breach: What to Know." [Online]. Available: <https://censinet.com/perspectives/lessons-change-healthcare-breach-what-to-know>
- [13] FIRST.org, "Exploit Prediction Scoring System (EPSS) Special Interest Group." [Online]. Available: <https://www.first.org/epss/>
- [14] J. Jacobs et al., "Enhancing Vulnerability Prioritization: Data-Driven Exploit Predictions with Community-Driven Insights," as referenced in EPSS documentation and secondary academic sources.
- [15] R. Parla, "Efficacy of EPSS in High Severity CVEs found in KEV," arXiv:2411.02618, 2024.
- [16] "Conflicting Scores, Confusing Signals: An Empirical Study of Vulnerability Scoring Systems," arXiv:2508.13644, 2025.
- [17] "Vulnerability Management Chaining: An Integrated Framework for Efficient Cybersecurity Risk Prioritization," arXiv:2506.01220, 2025.
- [18] I. Sarhan and M. Spruit, "Open-CyKG: An open cyber threat intelligence knowledge graph," Knowledge-Based Systems, vol. 233, p. 107524, 2021.
- [19] Y. Gao, X. Li, H. Peng, B. Fang, and S. Y. Philip, "HinCTI: A cyber threat intelligence modeling and identification system based on heterogeneous information network," IEEE Trans. Knowledge and Data Engineering, vol. 34, no. 2, pp. 708–722, 2020.
- [20] K. Kurniawan, A. Ekelhart, and E. Kiesling, "An ATT&CK-KG for linking cybersecurity attacks to adversary tactics and techniques," in Int. Semantic Web Conf. (ISWC) Posters and Demos, 2021.

- [21] Z. Li, J. Zeng, Y. Chen, and Z. Liang, "AttacKG: Constructing technique knowledge graph from cyber threat intelligence reports," in Proc. ESORICS, 2022, pp. 589–609.
- [22] F. K. Kaiser et al., "Attack hypotheses generation based on threat intelligence knowledge graph," IEEE Trans. Dependable and Secure Computing, 2023.
- [23] R. Fieblinger, M. T. Alam, and N. Rastogi, "Actionable Cyber Threat Intelligence using Knowledge Graphs and Large Language Models," arXiv:2407.02528, 2024.
- [24] K. Liu, F. Wang, Z. Ding, S. Liang, Z. Yu, and Y. Zhou, "A review of knowledge graph application scenarios in cyber security," arXiv:2204.04769, 2022.
- [25] M. Husák et al., "On the provision of network-wide cyber situational awareness via graph-based analytics," in Int. Conf. Complex Computational Ecosystems, Springer, 2023, pp. 167–179.
- [26] "Cybersecurity Threat Hunting and Vulnerability Analysis Using a Neo4j Graph Database of Open Source Intelligence," arXiv:2301.12013, 2023.
- [27] "On Holistic Multi-Step Cyberattack Detection via a Graph-based Correlation Approach," arXiv:2211.10971, 2022.
- [28] Microsoft, "GraphWeaver: Billion-Scale Cybersecurity Incident Correlation," arXiv:2406.01842, 2024.
- [29] I. Kotenko, D. Gaifulina, and I. Zelichenok, "Systematic literature review of security event correlation methods," IEEE Access, vol. 10, pp. 43387–43420, 2022.

Note: incident-reporting sources (CISA, Mandiant, Cyber Monitoring Centre, TechTarget, Wikipedia, etc.) are journalistic/industry/government advisory sources appropriate for motivating a research problem and are cited separately from the peer-reviewed academic references above; they should not be conflated with the peer-reviewed literature base when this document is adapted for formal submission.